

RESEARCH ARTICLE

A Verifiably Secure and Lightweight Device-to-Device (D2D) Authentication Protocol for the Resource-Constrained IoT Networks

NAIF ALZHRANI¹

College of Computer Science and Engineering, Department of Cybersecurity, University of Jeddah, Jeddah 23218, Saudi Arabia

e-mail: nsalzahrani@uj.edu.sa

This work was supported by the Deputyship for Research and Innovation, Ministry of Education in Saudi Arabia under Project MoE-IF-UJ-R2-22-04100412-2.

ABSTRACT Due to the growth of Internet of Things (IoT) devices on networks with limited resources, developing a safe and effective authentication method for Device-to-Device (D2D) communication has become necessary. Conventional authentication methods frequently have high communication and processing overhead, which makes them inappropriate for resource-constrained IoT networks. An innovative, lightweight, and verifiably secure D2D authentication protocol designed for resource-constrained IoT networks is proposed in this research. The protocol minimizes energy and computational costs while ensuring strong security by utilizing mutual authentication and effective cryptographic primitives. According to security analysis, the proposed protocol resists widespread attacks, such as DoS, replay, man-in-the-middle, and impersonation attacks. Additionally, the accuracy and security features of the protocol are confirmed by formal verification using commonly used techniques such as the ROR model and ProVerif validation. It is a feasible option for IoT deployments as performance examinations show considerable improvements over current systems regarding energy consumption, communication, computation, storage, and bandwidth utilization.

INDEX TERMS Authentication, vulnerability, ProVerif, cryptography, DoS attack, IoT, confidentiality.

I. INTRODUCTION

The Internet has made significant strides, paving the way for the Internet of Things (IoT) and its associated devices—such as wearable technology, smartphones, wireless sensors, laser scanners, and global positioning systems—which have garnered immense popularity. These devices are increasingly used across various applications, including retail, logistics, healthcare, and smart cities, as they offer intelligent computing and services. Over the past few years, the information exchanged between devices during task completion has shown considerable promise, hinting at a bright future for complex IoT systems [1]. In contrast to traditional castle-and-moat security models that rely on firewalls and intrusion detection/prevention systems to fend off external network attacks, the cryptographic-based authentication

model demands ongoing rigorous verification for access. This model employs robust cryptographic methods having a long secret number and a 160-bit public key, reflecting a more uncompromising approach to security. Within this framework, all users, devices, applications, networks, infrastructure, and data are presumed untrusted, necessitating exact verification for both internal and external access [2]. However, the rapid evolution of IoT has brought to the forefront a critical concern: the urgent need for dedicated authentication. This need is not just a future consideration but a pressing issue that requires immediate attention. To address this challenge and protect against all known threats, the contributions of technology experts, industry professionals, and researchers are invaluable. Their collaborative efforts are essential for ensuring the security of IoT systems [3].

Various authentication methods are developed and implemented to secure IoT devices (explained in this article's literature review section). However, these methods rely

The associate editor coordinating the review of this manuscript and approving it for publication was Renato Ferrero².

on a centralized authority, such as databases or system servers, built on a centralized architecture. Using various protocols, the centralized authority verifies end users, system IoT devices, and communication records between end users and IoT devices. Centralized authentication methods include identity-based authentication, certificate-based authentication, and mutual authentication [4]. High transactional computing costs, centralized trusted third parties, single points of failure, lack of privacy, and hacking risk are just a few of the numerous drawbacks of these methods [5]. These issues underscore the need for alternative, more secure solutions to mitigate these drawbacks.

A. PROBLEM STATEMENT

The existing device-to-device authentication methods in the designated domain exhibit significant security vulnerabilities, including susceptibility to an insider threat, a Man-in-the-Middle (MITM) attack, and a Denial-of-Service (DoS) assault. Additionally, these systems often require three to four round trips for authentication, contributing to inefficiency and delays. They are not suitable for real-time or resource-constrained environments due to their high computational time complexity and communication costs. Therefore, there is an urgent need for a robust, efficient, and secure device-to-device authentication scheme that addresses these vulnerabilities, decreases the number of round trips, and minimizes both computational and communication overhead. Once implemented, this new mechanism would be adaptable to various operational scenarios, providing reassurance about its applicability and reliability.

B. SIGNIFICANCE

Despite the growth and diversity of IoT applications and their potential to enhance human lives, numerous security and privacy concerns still need to be addressed. Due to their limited memory, CPU, battery, and power, IoT devices cannot defend themselves against attacks. This vulnerability makes them susceptible to being hacked, allowing attackers to launch a denial-of-service (DoS) attack easily. Many businesses have experienced such attacks using IoT devices, where the attacker took advantage of numerous IoT devices that mainly utilized default passwords, making them simple for attackers to inject. Given this serious flaw in IoT devices, there is a pressing need for a robust security mechanism to protect them from all known vulnerabilities, such as weak encryption, insecure network connections, and lack of secure update mechanisms.

C. CONTRIBUTIONS

The proposed ECC-based authentication protocol introduces key innovations that address critical challenges in resource-constrained IoT networks, setting it apart from existing ECC-based approaches. Unlike traditional methods that often rely on heavy certificate management, PKI, or complex pairing operations, the proposed authentication

protocol integrates lightweight yet secure ECC optimizations tailored for low-power IoT devices along with the SHA256 algorithm. Specifically, the protocol reduces computational overhead through efficient point multiplication techniques and minimizes communication costs by employing compact message formats without compromising security. Additionally, it enhances resistance against common attacks like replay, DoS, man-in-the-middle, and side-channel attacks by integrating dynamic key-update mechanisms and session-specific nonces. The proposed approach achieves a better trade-off between security robustness and energy efficiency than prior ECC-based schemes. It is particularly suitable for scalable IoT deployments with critical computation and power consumption. This contribution advances the state-of-the-art in device-to-device authentication and provides a practical, implementable framework for real-world IoT applications. The main contributions of this research work are demonstrated as follows:

- To propose a security mechanism without a password, utilizing a lightweight and robust asymmetric key cryptosystem and the SHA256 algorithm for device-to-device authentication in the rapidly expanding IoT market, reaching up to 75 billion in this year.

- To check the proof of correctness through a well-known and widely used Real-Or-Random (RoR) model, ProVerif verification, and pragmatic illustration.

- To measure the performance metrics by verifying the efficacy of the proposed device-to-device authentication scheme by considering computational time complexity, storage cost analysis, bandwidth utilization overheads, and energy consumption.

- To verify its feasibility regarding robustness and efficacy by comparing it with prior work, showing that the proposed device-to-device authentication scheme is superior to all its competitors, which is worth recommending for implementation.

D. ARTICLE STRUCTURE

Section II presents a comprehensive review of related work, highlighting the gaps in the current state of the article schemes. This will ensure up-to-date work and the novelty of the proposed scheme. In section III, the system model, including the network model, threat model, design goals, and technique used, will be elaborated in detail. Section IV will propose the D2D authentication scheme, and sections V and VI will analyze both the security and performance of the proposed D2D authentication scheme, along with a comparative analysis subsection. Finally, section VII presents the conclusion of the proposed research work.

II. RELATED WORKS

Unlike standard user authentication on computers, device-to-device authentication primarily uses wearables, IoT devices, and different embedded sensors to gather distinct identification information for mutual verification. This method, different from knowledge-based authentication techniques,

is increasingly used with devices. For instance, sensors, wearables, and IoT devices often let users enter PINs or lock patterns on the touch screen to verify them. It has recently been demonstrated that, with proper authentication, wireless communication interfaces like WiFi and Bluetooth, and motion sensors like accelerometers and gyroscopes can make daily life easier. In general, the several sensing technologies included in IoT devices provide the user with great versatility and ease regarding self-verification. In this connection, Shahidinejad et al. [1] proposed a lattice-based protocol for D2D authentication in the decentralized edge-computing network using blockchain technology. However, their scheme suffered from a DoS attack due to not using random credentials for such a dynamic environment. Shang et al. [2] proposed an authentication and key agreement protocol that merged the advantages of certificateless public key cryptography and elliptic curve cryptography (ECC) to guarantee secure and anonymous D2D group communications in 5G cellular networks. However, their scheme suffers from a forgery attack because the attacker can steal the session key generated and stored, and they can figure out the internal credentials from the key and later use it for malicious deeds. Shah et al. [3] proposed a D2D authentication utilizing a tunable mathematical function to generate dynamically changing session keys for continuous device authentication. However, according to extensive analysis, their scheme is not feasible for real-world scenarios, has high computational time complexity, communication costs, suffers from a DoS attack, and is completed in four round-trip because the exponential function in cryptography creates hurdles for real-world implementation. Schürmann et al. [4] proposed BANDANA (Body Area Network Device-to-device Authentication using Natural gAit) in which they claimed that during the transmission of vital signals from the human body by different devices are hacked by an attacker without facing any difficulty, but if their security mechanism which is based on fuzzy cryptography becomes implemented, then no one enters the network for any attack. According to extensive analysis, their scheme is not feasible for implementation; their scheme is theoretical, and no one knows how strong it is and how much cost it will deliver among different devices because they [4] never scrutinize its security formally, despite claims about the extraction of fresh credentials.

Kwon et al. [5] proposed an attribute-based encryption method for securing D2D communication in a multi-hop network. Before they [5] presented a protocol, they argued that a man-in-the-middle attack is the most common vulnerability in D2D communication; they then proved the vulnerabilities in different security mechanisms and presented their own mechanism. However, their scheme does not resist a DoS attack because it is based on static credentials, and the current session key is similar to the previous and upcoming session keys. Nandy et al. [6] proposed an ECC-based protocol for vehicles A and B utilizing pseudo-identity to ensure privacy and confidentiality. They scrutinized the security of their

protocol through BAN logic. They simulated through AVISPA, but their scheme does not resist a DoS attack. When the adversary takes its own timestamp, the system passes/verifies it and logs in to the authentication process for secure key generation because its scheme is without checks. Zargar et al. [7] presented an ECC-based protocol for IoT networks utilizing blockchain technology and the SHA-3 algorithm. However, a privileged insider can easily note the openly transmitted identity and use it for malicious purposes, which means [7] is prone to an insider attack because in the registration phase, the identity is sent openly to the server, which a privileged user can note, and later use for launching another attack. Sarkar et al. [8] proposed a lattice-based authentication protocol for D2D authentication using IoT networks utilizing quantum computing and blockchain technology. However, due to the non-availability of timestamps at the initial stages, their scheme is not resistant to side channels and DoS attacks.

Lee et al. [9] argued that devices are not delivering services for two-factor authentication schemes and are vulnerable to an ID/password pair guessing attack; so they proposed a three-factor authentication protocol utilizing ID, password, and PUF techniques for D2D authentication in the IoT environment. They [9] utilized their protocol proof of correctness through BAN logic, RoR model, and Scyther simulation; however, the last transmitted message between the gateway and device is vulnerable to side channel and DoS attacks because the attacker can easily take control there and disturb the whole authentication process due to the clock synchronization issue. Hajian et al. [10] proposed a protocol based on a simple hash function utilizing a gateway as middleware in the IoT environment; however, their scheme lacks resistance against password guessing attacks in both offline and online scenarios, as no random number was concatenated with the password to make it hard for an adversary. In order to address concerns about data security, device privacy, and infrastructure integrity in IoT ecosystems, Kumari et al. [11] introduced a lightweight mutual authentication mechanism for IoT devices employing fog-based computing. Their [11] protocol ensures secure data exchange and resilience to different security threats.

In order to offer a safe and effective authentication technique for M2M communication in industrial IoT contexts, Sengar et al. [12] proposed an ECC-based secure authentication protocol for M2M communication in industrial IoT edge devices. Using chord architecture and encryption approaches, Liu et al. [13] introduced two new two-factor authentication solutions for IoT devices that increase overall security and significantly improve efficiency by reducing memory use, improving reaction time, and minimizing communication latency. However, their schemes [12] and [13] don't tackle the globally changing time synchronization issue, and the synchrony of shared secrets is not tackled efficiently.

Cui et al. [14] introduced an effective device communication authentication protocol designed for large-scale IoT

TABLE 1. Summary of the literature.

Ref	Methodology	Domain	Limitations
[16]	PKI, SHA and XOR	Device to Drone	Insider attack
[17]	ECC, MD5 and XOR	Device to Server	- Poor performance - Hash Collision attack
[18]	ECC, MD5 and XOR	IoT environment	- Insider attack - Hash Collision attack
[19]	CRC, ECC, and SHA	Device to Device	- DoS attack - Privileged insider attack
[20]	ECC, SHA, and XOR	Device to Device	- Reply attack - Man-in-the-middle attack
[21]	ECC, SHA2, and XOR	Device to Server	- Desynchronization attack - Clock synchronization issue
[22]	ECC, SHA2, and XoR	Device to Device	- DoS attack - Impersonation attack

environments, emphasizing the standardization of protocol formats and ensuring reliable transmission while authenticating the identities of communication nodes to enhance security in D2D interactions. Addressing authentication challenges using an editable blockchain, Byzantine fault tolerance, and an online/offline signature algorithm, Li et al. [15] proposed the BLMA protocol, a lightweight identity authentication scheme for IIoT devices. However, in both schemes [14] and [15], the ephemeral secrets are leaked to the attacker because the randomly generated numbers do not provide forward secrecy capability. Their [15] protocol enhances security and provides a reliable and robust solution for IoT security, ensuring reliable transmission during D2D authentication—the summary of the remaining literature review (critical analysis) is shown in Table 1.

For IoT and IIoT applications, Singh et al. [23] proposed a simple authentication scheme to minimize vulnerabilities, lower computational costs, tackle serious security issues, and strongly emphasize mutual trust in IoT devices. In their scheme [23], the registration center created the secret and public parameters for independent devices. Their plan, however, is vulnerable to ESL attacks because the generation of too-random numbers creates a hurdle for the system and exposes it to the adversary for leakage. Song et al. [24] proposed an authentication scheme using blockchain technology for a cloud-assisted telecare medical information system (TMIS) utilizing ciphertext-policy attribute-based encryption (CP-ABE) to manage health data; although it is susceptible to insider threats because the secret key stored is not in cipher-text format and plain text is easily vulnerable to an attacker. A three-factor authentication system using ECC was developed by Sahoo et al. [25] for healthcare systems that use IoT devices. However, it is vulnerable to replay and forgery attacks because the identity is transmitted openly over the public network channel; an attacker can capture and launch a replay attack and forge the necessary credentials from the system.

The existing D2D authentication methods in the designated domain exhibit significant security vulnerabilities,

including susceptibility to an insider threat, Man-in-the-Middle (MITM) attack, replay, and Denial-of-Service (DoS) attacks. Additionally, these systems often require four to five round trips for authentication, contributing to inefficiency and delays. They are not suitable for real-time or resource-constrained IoT environments due to their high computational time complexity and communication costs. Therefore, there is an urgent need for a robust, efficient, and secure D2D authentication scheme that addresses these vulnerabilities, decreases the number of round trips, and minimizes both computational and communicational overheads. Once implemented, this new mechanism will be adaptable to various operational scenarios, providing reassurance about its applicability and reliability.

III. PRELIMINARIES AND BACKGROUND

This section outlines the fundamental concepts and frameworks that form the foundation for understanding the proposed solution. Key elements include the adversarial or threat model, the network model, the design objectives, and other relevant terms. Below, these foundation topics/concepts are explained one by one as follows:

A. NETWORK MODEL

The network model described in this section of the article is centered around a control server responsible for registering the devices, a crucial function that it performs independently for the authentication process. It registers the devices offline and securely, ensuring that no credentials are leaked to potential intruders, as illustrated in Figure 1. It is worth noting that the ECC is an asymmetric cryptographic approach that works like this: the sender device encodes/decodes the plain text using the public key and transmits the cipher text to the other device, which encrypts/encodes using the private key. The ECC generates 160-bit keys, which are hard for an adversary to forge/identify. They are lightweight in nature and are a very accurate solution for resource-constrained devices.

B. THREAT MODEL

The threat model is a comprehensive tool that identifies potential adversaries, their capabilities [30], and the diverse range of attacks the system must defend against [26]. For instance, an adversary can execute DoS, MITM, or insider attacks. They can exploit the open network channel to gain control by manipulating or eavesdropping on the exchanged information. Adversaries can also impersonate legitimate entities, overwhelm devices with excessive requests, intercept and alter communication, compromise legitimate devices, and gain access to cryptographic tools, network traffic, or partial control over the system [27]. The attacker might inject false information, divert the flow of packets, or legitimate themselves as a legal participant.

C. DESIGN GOALS

Upon designing the proposed protocol, the primary focus should be on the following key features:

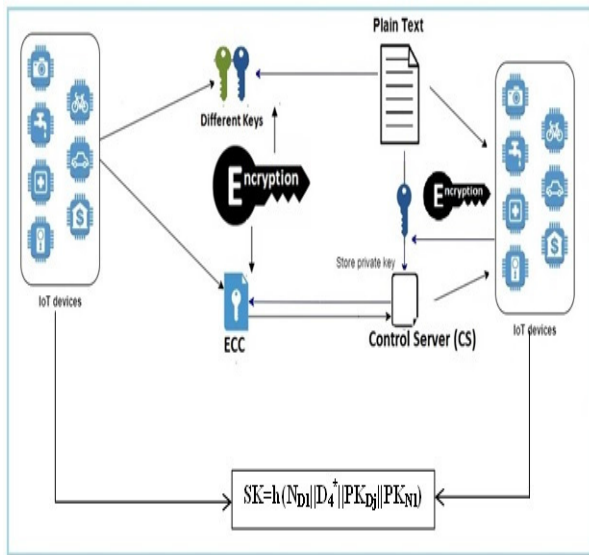


FIGURE 1. Proposed network model.

- **Security:** Ensuring data confidentiality, integrity, and authenticity.
- **Resilience:** The proposed D2D authentication mechanism should maintain functionality despite adversarial activities or network disruptions.
- **Low Computational Complexity:** The proposed protocol significantly minimizes the computational overhead, communication cost, and energy consumption, highlighting its feasibility in the resource-constrained environment.
- **Scalability:** The proposed D2D authentication mechanism must support a large number of devices, consume less energy, work in low-latency networking, and have minimal data transmission delay without degradation in performance.
- **Efficiency:** The proposed mechanism is meticulously designed to minimize the number of round trips, ideally one to two, ensuring a swift and robust authentication process. The minimum round doesn't allow anyone to take control of the transmission process.

D. SHA-256

The National Security Agency (NSA) created the Secure Hash Algorithm 256-bit (SHA-256), a cryptographic hash function that is the successor of the SHA-2 family. The National Institute of Standards and Technology (NIST) released it in 2001 [28]. The following are the main characteristics of SHA-256, which is extensively utilized in many security applications and protocols:

- A 256-bit (32-byte) hash value, usually a 64-character hexadecimal number, is produced using SHA-256.
- The hash output will always be the same for the same input.
- The hash function cannot be reversed computationally.

- Even a single-bit alteration in the input can significantly impact the hash output.
- It is improbable that two distinct inputs would result in the same hash output.

E. PROVERIF

An automated tool for verifying cryptographic protocols, ProVerif [29], is used to assess the security of cryptographic systems and protocols. Its foundation in formal techniques and symbolic representations makes it an effective tool for establishing security characteristics, reassuring the audience about its reliability. ProVerif is often used in businesses and academia to validate protocols, including key exchange, authentication, and privacy-preserving systems. The Dolev-Yao paradigm [30], which ProVerif employs, treats cryptographic primitives (such as encryption and signatures) as abstract processes instead of bit-level calculations. Digital signatures, hash functions, symmetric and asymmetric encryption, and other cryptographic processes are all supported by ProVerif. It can model intricate cryptographic structures, concurrent sessions, and multi-participant protocols.

F. ROR MODEL

The Real-or-Random (RoR) model [30], [31], a versatile security framework, is used to design and evaluate the security of cryptographic primitives, especially key exchange protocols and encryption methods. Its frequent use in formalizing semantic security, which prevents attackers from deducing significant information about the plaintext from the ciphertext, underscores its importance. The model's role in establishing the security of key exchange mechanisms, ensuring the indistinguishability of derived session keys from random values, and defining security for symmetric and asymmetric encryption highlights its versatility and confidence in the system's security.

G. ELLIPTIC CURVE CRYPTOGRAPHY (ECC)

A contemporary public-key encryption technique called Elliptic Curve encryption (ECC) [32] impressively utilizes the mathematical characteristics of elliptic curves over finite fields. With much reduced key sizes, ECC offers the same degree of security as conventional public-key cryptosystems (such as RSA [33]) while being more computationally, storage- and bandwidth-efficient. The mathematical equation $y^2 = x^3 + ax + b$, where a and b are coefficients, is satisfied by a collection of points (x, y) that make up an elliptic curve. The curve is defined over a finite field, usually a prime field F_p or a binary field F_{2^m} . One special characteristic of the curve is that any straight line that crosses it at two places will do so at precisely one more point, which defines the group operation. The Elliptic Curve Discrete Logarithm Problem (ECDLP) [32] is essential to ECC's security: It is computationally impossible to find the scalar d such that $Q = d \cdot G$ given points G and Q on the curve. Compared to the discrete logarithm

TABLE 2. Notations and their descriptions.

Symbol	Descriptions
CS	Control Server
P	Point over curve
PK	Public key
ID _{Dj}	Device j identity
N _{CS}	Nonce of the Control Server
N _{Dj}	Nonce for device j
h(.)	Hash function
PK _{D1}	Public key of device i
T _c	Current timestamp
T	Recorded timestamp
D	Device
k	Secret key
ID _{Di}	Device i identity
PK _{N1} , PK _{N2}	Public keys
N _{Di}	Nonce of Device i
⊕	XOR operation
	Concatenation Function
PK _{D2}	Public key of device j
ΔT	Maximum delay
R	Random number
A	Adversary

problem in finite fields or the integer factorization problem used in RSA [33], this problem is considered exponentially more difficult.

IV. PROPOSED PROTOCOL

In this section of the article, the D2D authentication protocol shall be presented. This protocol is consisted of three phases including setup phase, registration phase, and authentication phase. These phases are described one by one as under, while the notations defined for the design of the protocol is illustrated in Table 2.

A. SETUP PHASE

The control server (CS) selects k as a secret key, and a curve (E) from the equation $y^2 = x^3 + a_1x + a_2$ over a finite field (F_q) belongs to prime order q , whereas a_1 and a_2 are two points in the curve (E) . Afterward, the control server selects a base point P from the curve $E(F_q)$ of order prime, computes the public key $PK = k.P$, selects a hash function h , and publishes $\{a_1, a_2, P, PK, h(\cdot)\}$ as public parameters and keeps k as the secret key. The system is designed with the adversary in mind, ensuring that they will never break the public key due to generating through the elliptic curve discrete logarithmic problem (ECDLP), P is a point in the curve over a finite field, while Q is the point at infinity such that $n.P = Q$.

B. REGISTRATION PHASE

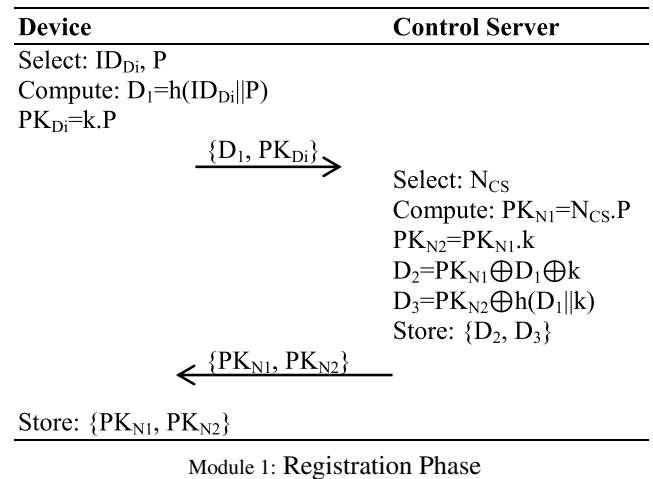
This phase of the protocol is completed in the following steps:

Step 01: A legitimate user selects identity for a device i , i.e., ID_{Di} , and chooses a point P the device calculates

$D_1 = h(ID_{Di} || P)$, computes the public key $PK_{Di} = k.P$ and sends $\{D_1, PK_{Di}\}$ to the control server (CS) over a private channel in offline mode.

Step 02: The control server (CS), when receiving $\{D_1, PK_{Di}\}$ message, first checks the identity in its record; if found, it should tell the user to choose another identity, but if not, the control server (CS) generates a nonce N_{CS} , calculates $PK_{N1} = N_{CS}.P$, $PK_{N2} = PK_{N1}.k$, $D_2 = PK_{N1} \oplus D_1 \oplus k$, $D_3 = PK_{N2} \oplus h(D_1 || k)$, stores $\{D_2, D_3\}$ and sends $\{PK_{N1}, PK_{N2}\}$ back to the device over a private channel.

Step 03: When receiving the $\{PK_{N1}, PK_{N2}\}$ message, it stores these keys in its memory, as shown in Module I and depicted in Figure 2.



C. AUTHENTICATION PHASE

This is the most crucial step of the proposed protocol. It consisted of complex computations steps, steps are explained as follows:

Step 01: The device i selects a nonce N_{Di} , computes $PK_{D2} = N_{D1}.P$, $D_4 = N_{Di} \oplus h(D_1 || N_{Di} || PK_{Dj}) || PK_{N2}$ and sends $\{D_4, PK_{D2}, PK_{Di}, PK_{N1}\}$ parameters to device j over a public channel.

Step 02: Device j , when receiving the $\{D_4, PK_{D2}, PK_{Di}, PK_{N1}\}$ message from Device i , Device j undertakes a series of steps to verify the message's legitimacy by subtracting the received timestamp from the current time stamp of the system, if found within the pre-defined threshold, should be considered a legitimate replay, else, denied for potential DoS attack. The device j first selects a nonce N_{Dj} , computes $PK_{D2} = N_{Dj}.P$, $D_4^* = N_{Dj} \oplus h(D_1 || N_{Dj} || PK_{Di}) || PK_{N2}$, checks whether D_4^* matches D_4 ; if found identical, it computes the session key $SK_{Dj} = h(N_{D1} || D_4^* || PK_{Dj} || PK_{N1})$ and sends $\{D_4^*, PK_{D1}, PK_{Dj}, PK_{N2}\}$ message to back to the device i over a public channel.

Step 03: The $\{D_4^*, PK_{D1}, PK_{Dj}, PK_{N2}\}$ message from device j , when received by device i , check the legitimacy by subtracting the received timestamp from the current time stamp of the system, if found within the pre-defined threshold, should be considered a legitimate replay, else, denied for

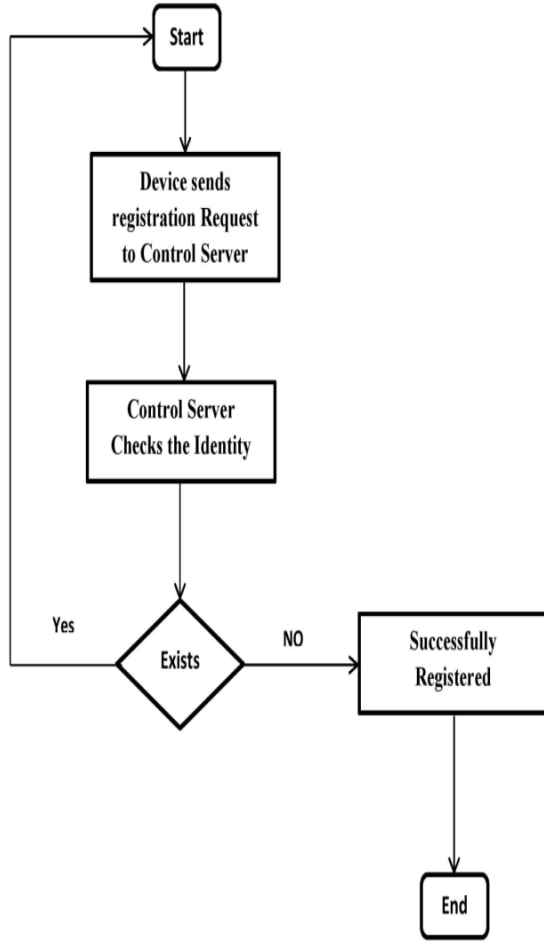


FIGURE 2. Flow chart representation of the registration phase.

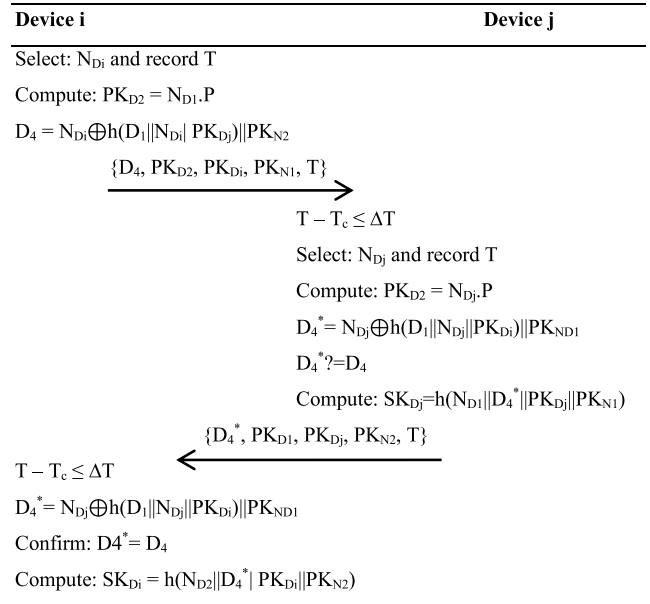
potential DoS attack, verifies if D_4^* matches D_4 and then computes the session key $SK_{Di} = h(N_{D2} || D_4^* || PK_{Di} || PK_{N2})$. At this point, both devices i and j are authenticated and ready for secure communication, as shown in Module 2, plotted its flow chart in Figure 4, and algorithmically in Figure 3.

V. SECURITY ANALYSIS

The proof of correctness and robustness of the proposed protocol will be analyzed formally using ROR model [30], [31], ProVerif simulation and informally through lemmas. The real-or-random (RoR) model will be used for the security analysis of the proposed protocol to check the proof of correctness and robustness. This analysis is also called the formal analysis, which is given as follows, while the notation utilized for the analysis is demonstrated in Table 3.

A. ROR ANALYSIS

The RoR model utilized by [32] and [33] is a solid solution for the correctness and robustness of the proposed protocol. Let 'P' represent the protocol, $\bar{A}$ means the adversary, and i represent the i^{th} instance of D_i , and j is the j^{th} instance of



Module 2: Authentication Phase

ALGO:-I: ALGORITHMIC REPRESENTATION OF THE AUTHENTICATION OF DEVICE i and DEVICE j

```

1: Input:  $N_{Di}, T, N_{Dj}$  and  $PK_{N1}, PK_{N2}$ 
2: Output: SK
3: Compute:  $PK_{D2} = N_{D1} \cdot P$ 
4:  $D_4 = N_{Di} \oplus h(D_1 || N_{Di} || PK_{Di}) || PK_{N2}$ 
5: if ( $T \neq T_c$ )
6:    $PK_{D2} = N_{Dj} \cdot P$ 
7:    $D_4^* = N_{Dj} \oplus h(D_1 || N_{Dj} || PK_{Di}) || PK_{ND1}$ 
8:   if ( $D_4^* = D_4$ )
9:      $SK_{Dj} = h(N_{D1} || D_4^* || PK_{Dj} || PK_{N1})$ 
10:    if ( $T \neq T_c$ )
11:       $D_4^* = N_{Dj} \oplus h(D_1 || N_{Dj} || PK_{Di}) || PK_{ND1}$ 
12:      if ( $D_4^* = D_4$ )
13:         $SK_{Di} = h(N_{D2} || D_4^* || PK_{Di} || PK_{N2})$ 
14:        return(SK)-pass
15:      else
16:        return(0)-null
17:    else
18:      return(SK)-pass
19:    else
20:      return(0)-null
21:  else
22:    return(0)-null
23: return(SK)-pass
24: else
25: return(0)-null
  
```

FIGURE 3. Algorithmic representation of the authentication phase.

D_j , then the adversary $\bar{A}$ insistently executes the different queries within an oracle to break 'P'. As stated, the main entities in the proposed protocol are the CS, Device i (D_i), and Device j (D_j). These entities, represented as $\prod_{CS}^i, \prod_{D_i}^i$, and

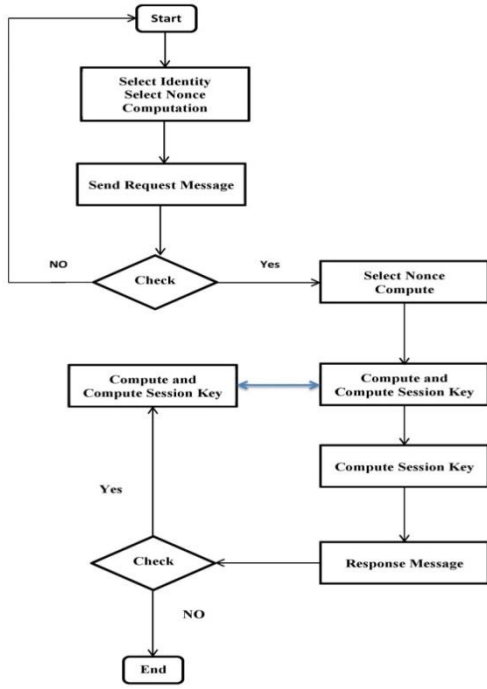


FIGURE 4. Flow chart representation of the authentication phase.

TABLE 3. ROR notations and their illustration.

Notation	Illustration
CS	Control Server
D_i	Device i
D_j	Device j
Π	Instance
$\bar{A}$	Adversary
R	Random output
SK	Session key
P	Protocol
η	Small value
Prob	Probability
W	Win
ADV	Advantage
Q_H	Hash Query
Q_S	Send Query
Q_E	Execute Query
d_1	Hash Length
d_2	Transcript
k	Secret key
m	Message
PK	Public key
ϵ	Small quantity

$\Pi_{D_i}^k$, respectively, play fundamental roles in the protocol's operation. In the authentication, Device I (D_i) and Device J (D_j) are mainly involved, so these two participants will be analyzed for the correctness and robustness of the proposed scheme. The adversary's actions toward running the queries are stated as under:

♦ **Accepted State:** If the oracle receives accurate input from $\bar{A}$, it goes for correct execution and generates the valid session key SK, called accepted state.

♦ **Null State:** If the oracle receives input and generates nothing (null), then it is a null state.

♦ **Partnering:** The participants $\Pi_{D_i}^i$ and $\Pi_{D_j}^j$ are partners when their session keys are equal ($SK_i = SK_j$), identities are equal ($ID_{D_i} = ID_{D_j}$), nonces are equal ($N_{D_i} = N_{D_j}$), or public keys are equal ($PK_{D_i} = PK_{D_j}$) and matched.

The adversary $\bar{A}$ can be given an input m to $\Pi_{D_i}^i$. If the output they get is SK_i , it means the adversary $\bar{A}$ has successfully forges SK from D_i . However, for the adversary $\bar{A}$ to perform such attacks, they must be able to run the following queries:

♦ **Execute** $(\Pi_{D_i}^i, \Pi_{D_j}^j)$: In this query, the successful correspondence between $\Pi_{D_i}^i$ and $\Pi_{D_j}^j$ is seized by adversary $\bar{A}$.

♦ **Send** $(\Pi_{D_i}^i, m)$: If the out from $\Pi_{D_i}^i$ becomes correct on sending message m by an adversary $\bar{A}$, it means $\Pi_{D_i}^i$ is responded accurately.

♦ **Reveal** $(\Pi_{D_i}^i, \Pi_{D_j}^j)$: If, from any input, the partners gets an output in the form of a tuple and the adversary agrees that the tuple they get is SK, and then both partners mutually exchange information to each other in a correct manner.

♦ **Test** $(\Pi_{D_i}^i)$: If the adversary $\bar{A}$ doesn't succeed, at least they get a random output, say R. If the value of R is 1, it means actual SK; otherwise, the adversary returns the R.

♦ **Corrupt** $(\Pi_{D_i}^i)$: It returns the N_{CS} , N_{D1} , N_{D2} , k, and PK stored in the devices (D_i and D_j).

♦ **Freshness:** If the session key of Device i is equivalent to the session key of Device j and is in the accepted states, but the identities are not equal, then this condition is called freshness.

♦ **Semantic Security:** When the adversary $\bar{A}$ runs the test(.) query and gets the following equation, it represents a random number R, the winning probability with $\bar{A}$ is represented by $ADV_A^P = |2Prob[W(A)] - 1|$. If $ADV_A^P > \eta$, whereas η is an appropriately small value, then the protocol is said to be insecure.

Suppose Q_H , Q_S , and Q_E are hash, send and execute queries, d_1 means the length of hash, d_2 is a necessary transcript, and d_3 means ECC key. Then, the advantage with $\bar{A}$ in cracking the ECDLP secured key is represented in eq:

$$ADV_A^P \leq \frac{(Q_H)^2}{2^{d_1}} + \frac{(Q_S + Q_E)^2}{d_2} + \frac{Q_S}{2^{d_3-1}} + 2Adv_A^{ECDLP}(\epsilon) \quad (1)$$

whereas ϵ means arbitrarily small quantity/fewer chances with $\bar{A}$ in breaking the ECDLP-based ECC key; To further simulate the winning chances of $\bar{A}$ regarding the proposed protocol for different attacks as represented as under:

$$ADV_A^P = |2Prob[W_0] - 1| \quad (2)$$

Eq: (2) means the advantage with $\bar{A}$ in launching the actual attack on 'P'. While for eavesdropping attack, the chances as given as under

$$ADV_A^P = |2Prob[W_1] - 1| \quad (3)$$

Put the right-hand side of eq: (3) in the left-hand side of eq: (2), and we get

$$\text{Prob}[W_0] = \text{Prob}[W_1] \quad (4)$$

Eq: (4) means the message transmitted between $\Pi_{D_i}^i$ and $\Pi_{D_j}^j$ in the Execute $(\Pi_{D_i}^i, \Pi_{D_j}^j)$ query, test by the Test $(\Pi_{D_i}^i)$ query, and return SK, which is impossible due to ECDLP. If the attacker chooses a tuple d_2 (necessary transcript) and creates hash code from it for launching a hash collision attack, then the winning advantage with $\bar{A}$ is represented as:

$$\text{Prob}[W_2] - \text{Prob}[W_1] \leq \frac{(Q_H)^2}{2^{d_1+1}} + \frac{(Q_S + Q_E)^2}{2d_2} \quad (5)$$

For recovering the information stored in the memory of device i and device j, the winning chances with $\bar{A}$ are given under

$$\text{Prob}[W_3] - \text{Prob}[W_2] \leq \frac{Q_S}{2^{d_3}} \quad (6)$$

The nonce generated by device i is N_{D_i} , and device j is N_{D_j} , the ECC key of device i is PK_{D_i} and device j is PK_{D_j} , secret key k and PK_{CS} is used for calculating the session secret key SK, and the winning chances with $\bar{A}$ is given as

$$\text{Prob}[W_4] - \text{Prob}[W_3] \leq \text{Adv}_A^{\text{ECDLP}}(\epsilon) \quad (7)$$

For nonce guessing, the winning advantage with $\bar{A}$ is

$$\text{Prob}[W_4] = \frac{1}{2} \quad (8)$$

Combine these chances of $\bar{A}$, we get

$$\begin{aligned} \frac{1}{2} \text{ADV}_A^P &= \left| \text{Prob}[W_0] - \frac{1}{2} \right| \leq \frac{(Q_H)^2}{2^{d_1}} + \frac{(Q_S + Q_E)^2}{d_2} \\ &+ \frac{Q_S}{2^{d_3-1}} + 2\text{Adv}_A^{\text{ECDLP}}(\epsilon) \end{aligned} \quad (9)$$

Eq: (9) can also be written as:

$$\text{ADV}_A^P \leq \frac{(Q_H)^2}{2^{d_1}} + \frac{(Q_S + Q_E)^2}{d_2} + \frac{Q_S}{2^{d_3-1}} + 2\text{Adv}_A^{\text{ECDLP}}(\epsilon) \quad (10)$$

Thus the analysis demonstrates that the session keys generated throughout the authentication process are guaranteed to be identical to random values by the protocol. Even with access to protocol transcripts and other public data, an adversary cannot differentiate between a real session key and a random value. The analysis shows that under the assumptions of ECDLP [34], the adversary's advantage in describing the difference between real and random session keys is minimal. The presented authentication technique offers semantic security for session keys after it was formally examined using the Real-Or-Random (ROR) paradigm. Additionally, the protocol provides forward secrecy, mutual authentication, and defense against replay and man-in-the-middle attacks, promising a secure and efficient authentication process.

B. INFORMAL ANALYSIS

The proposed protocol can also be informally analyzed using pragmatic illustrations and lemmas, as described for various attacks, highlighting its security features. These are explained as under:

Lemma 1: The proposed protocol provides untraceability & anonymity.

Proof: The proposed method takes a proactive approach by securing the communications among the different devices exchanged messages publically. It must not transmit a true identity, ID_{D_i} , across public channels, meaning an attacker would need to derive ID_{D_i} to identify ID_{D_j} from D_1, D_2, D_3 . However, due to the complexity of the Elliptic Curve Discrete Logarithm Problem (ECDLP), it remains infeasible for the attacker to obtain ID_{D_i} . Moreover, openly transmitted messages in each session are much secure in the proposed technique that can ensure user anonymity and untraceability.

Lemma 2: The session key disclosure and replay attacks are not possible on the proposed protocol and offers perfect forward secrecy.

Proof: The computation of the session keys SK_{D_i} and SK_{D_j} is very hard for an adversary to break due to ECDLP; also, the attacker cannot compute previous session keys even when they are aware of the private keys k and public key PK . The dynamically generated nonce and random numbers is further enhanced by the freshness of N_{D_i}, N_{D_j} , and N_{CS} , which ensures that an attacker cannot compute prior or upcoming session keys even after obtaining the current session key. As a result, the proposed approach offers forward secrecy and is resistant to replay and session key disclosure attacks.

Lemma 3: Offline identity guessing attack is impossible in the proposed protocol.

Proof: The attacker, suppose, tries to guess ID_{D_i} from the device i or device j, and assuming that an attacker obtains random numbers and keys, as the ID_{D_j} tightly bound with the ID_{D_j} and the nonce simultaneously. When ID_{D_j} consists of n letters and the hash value is 160 bits, the guessing chance is about $1/26^n + 160$, making it an infeasible issue to solve it computationally. This infeasibility underscores the magnitude of the challenge and the need for innovative solutions. As a result, the proposed technique makes it impossible to predict an identity accurately in offline manner.

Lemma 4: The proposed protocol withstands a hash collision attack.

Proof: Consider a scenario involving a collection of n servers where (t', ϵ') can generate a valid secret key (SK). If the conditions are met such that $t \leq t' + 2 \text{Prob}(2n + 2q(P_{\text{pub}}) + n_q P)$ and $\epsilon \geq ((\epsilon'/e)(1 + q_k)) / 2$, then there exists a possibility for accessing the internal parameters of the key ECDHP through a challenger. This challenger will make t attempts, provided that, after executing polynomial-time computations, an adversary ($\bar{A}$) can produce at most q_S keys and q_H hash queries through inversion or exponentiation on curve point P . Thus the proposed protocol is safe against a hash collision attack.

Lemma 5: *The session key and hash code are not revealed to the adversary in the proposed protocol.*

Proof: Let's consider a scenario where adversary $\bar{A}$ reaches and executes the hash code and session key in time t , generating a query attempts at most t times, where d_s and d_i denote the random oracle queries to h . The challenge of the Elliptic Curve Computational Diffie-Hellman (ECDH) [34] problem is prioritized at $\varepsilon' \geq (1/d_1)$, which can be demonstrated using an algorithm, denoted as B , that operates within a time bound of $t \leq t + (d_1 + d_2 + d_{key} + 4d_s)$. The computation of scalar multiplication is represented by τ_s . While $\bar{A}$ may be able to compromise the scheme, it is challenging for $\bar{A}$ to utilize B to recover the internal credentials, as it becomes secure by ECDLP, which results in a random tuple $(P, k.P)$. Initially, B sets the system parameters $\{k, kP, PK\}$ and organizes the functions $h(\cdot)$ as a random oracle under its control. To target the identity of a legitimate device, B selects $k \in [1, d_1]$; if $k \neq i$, it computes Z_q^* ; otherwise, it queries PK but not kP . Despite $\bar{A}$'s efforts, the attempt to successfully calculate the entire set of tuples/queries about the user's identity ultimately proves unsuccessful, showcasing the system's resilience toward session key and hash code.

Lemma 6: *The proposed protocol is safe against a forgery attack.*

Proof: During the initialization phase, computing the SK using the CDHP is complex. An adversary $\bar{A}$ could forge a valid key if k or PK values equal to zero during this computation then it means they are failed. This involves the adversary $\bar{A}$ extracting specific secret values, such as $k, PK_{D1}, PK_{D2}, N_{D1}$, and N_{D2} , and selecting some values $N_{CS} \in Z_q^*$ while assuming $k = 1$ for a message M , along with the system's public key PK . The adversary then hashes the query to obtain output from the system before relaying the message. At this point, they would have to flip a coin for a chance to succeed. Depending on the outcome, the adversary either receives no value (with the coin flip resulting in zero) or the SK, which the adversary cannot compute or identify in reality. The adversary must perform n scalar multiplications for hash queries and carry out ECC additions for key queries to obtain this result. Once the allotted time for completing such extensive computations has elapsed, the adversary cannot successfully forge the key for the subsequent task.

Lemma 7: *Ephemeral Secret Leakage (ESL) is not valid for the proposed protocol.*

Proof: The device i and device j select random nonces N_{D1}, N_{D2} , and N_{CS} from Z_q^* to send a challenge to the cross-participant. Suppose adversary $\bar{A}$ has at most a $1/[D]$ probability of obtaining the secret key SK from the control server. This probability is related to its private key k , which means that if k is located at a curve point and the public key PK is elsewhere, then if $1 \leq p \leq k$, $\bar{A}$ cannot extract the internal credentials of any device. Each device's identity is uniquely determined in a valid oracle by the control server: $k \in Z_q^*$ and $PK \in Z_q^*$, with $PK = k.P$ and $PK_{D1} = PK.P$, where P is a point on an elliptic curve over a finite field F_q . This

setup is secured by the Elliptic Curve Discrete Logarithm Problem (ECDLP) [34], preventing adversary $\bar{A}$ from making any calculations to derive the secret keys. Consequently, the secret of the control server, devices i and j , are protected during communication from all angles.

Lemma 8: *The proposed protocol is resisting both Type-I and Type-II adversary.*

Proof: Assume that there are two types of adversaries: type I adversaries are those who know the system's Longterm key, PK , and type II adversaries are those who know the private key, k . We have a security model based on SHA256 and ECC for real-time surveillance. If no adversaries of type I, type II, or both are probabilistic polynomial time, they cannot establish a secure connection with the system. First, the adversary provides challenger C with a security parameter. If they are type I, C can retrieve the PK by running the setup method and exchanging the result with A . Only when $\bar{A}$ is given the most extraordinary access power is feasible. However, the proposed security model is much more secure because all the keys are securely generated through ECDLP, which requires extensive calculation, and such calculation requires time; the system doesn't allow anyone to do such calculations; it discards any illegal request and considers an outdated message.

C. PROVERIF SIMULATION

This widely utilized software verification toolkit evaluates a security protocol's confidentiality, authorization, and reachability. The proposed protocol has been implemented using ProVerif, and the summary of the results below illustrates that the attacker could not hijack the session secret key. Notably, each peer's security performed all cryptographic operations by generating ECC keys, hash codes, and random nonces, ensuring the protocol's robustness and security.

Verification Summary:

```
Query inj-event(end\_Devicei(IDDi[])) ==>
    inj-event(start\_Devicei(IDDi[])) is true.
Query inj-event(end\_CS(IDcn[])) ==>
    inj-event(start\_CS(IDcs[])) is true.
Query inj-event(end\_Devicej(IDDj[])) ==>
    inj-event(start\_Devicej(IDDj[])) is true.
```

The simulation results obtained from executing the ProVerif code demonstrate the robustness and correctness of the proposed protocol in terms of confidentiality. This protocol involves a control server (CS), device i (D_i), and device j (D_j), and it has been thoroughly analyzed using the widely recognized formal verification toolkit, ProVerif. The findings indicate that: 1) the protocol effectively defends against

TABLE 4. Computation cost for cryptographic operations.

Operation Name	Represented by	Execution Time in Milliseconds (ms)		
		Server	Device i	Device j
Hash Function	T_H	0.189	0.774	0.981
Multiplication	T_X	0.567	0.954	1.051
Addition	T_+	0.014	0.046 ms	0.248
Random number extraction	T_{RM}	2.024	2.581	2.987
Encryption function	T_E	0.561	0.913	1.054
Decryption function	T_D	0.561	0.913	1.054
Scalar Multiplication	T_S	0.0.274	0.983	1.041
XOR Operation	T_{XOR}	0.0000104 $\approx$ 0	0.00000224 $\approx$ 0	0.0000915 $\approx$ 0
Concatenation Function	T_C	0.0000457 $\approx$ 0	0.00000921 $\approx$ 0	0.0000214 $\approx$ 0

replay, man-in-the-middle, and session key hijacking attacks; 2) it ensures key confidentiality and forward secrecy; and 3) it verifies the validity, resilience, and reachability of the session secret key.

VI. PERFORMANCE ANALYSIS

For the performance analysis, the computational time, communication costs, and storage overheads will be measured one by one as follows:

A. COMPUTATION COST ANALYSIS

An exhaustive implementation experiment was conducted for the proposed authentication protocol through a Raspberry Pi 5, a cell phone, and a Core i7 laptop to evaluate the computation cost and energy consumption. It is worth mentioning that the results obtained from the cell phone should be attributed to device i, while those from the Raspberry Pi pertain to device j. The Core i7 laptop, a crucial component, will serve as the cloud server, as illustrated in Table 4.

A: The Raspberry Pi 5 has a Broadcom BCM2712 2.4GHz, quad-core, 64-bit Arm Cortex-A76 CPU, 2 GB of RAM, and dual-band 802.11ac Wi-Fi. These specifications were chosen for compatibility and optimal performance with the MIRACL Crypto SDK [35], a widely used cryptographic library for resource-constrained devices, which was a key consideration in the hardware selection process.

B: The Samsung Galaxy A21s smartphone features a 2.0 GHz Cortex-A55 processor with four cores at 2.0 GHz Cortex-A55, 6 GB of RAM, and an Android operating system.

C: An Intel® Core™ i7-6500U CPU powers the Core i7 laptop with a base speed of 2.50 GHz and a burst speed of 2.59 GHz.

Considering the computation costs presented in milliseconds (ms) in Table 4, the proposed protocol's summarization is provided in Table 5 and illustrated diagrammatically in Figure 5. The entire scheme involves 14 hash cryptographic operations, eight multiplication functions, the extraction of random numbers occurring seven times, six instances of scalar multiplication, and nine XOR operations. This can be represented as $14T_H + 8T_X + 7T_{RE} + 6T_S + 9T_{XOR}$, resulting in a total computation cost of 28.83 ms. The

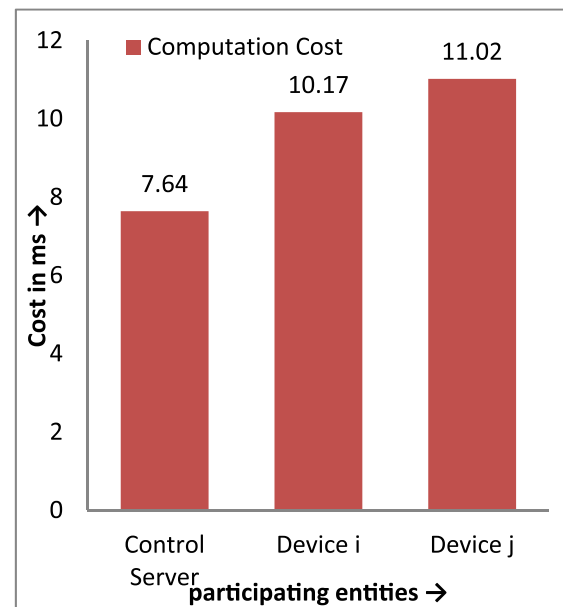
**FIGURE 5.** Computation cost analysis.

figure depicts the computational costs associated with the authentication protocol across various participating entities, measured in milliseconds (ms). The Control Server exhibits the highest computational cost at 11.02 ms, followed by Device i at 10.17 ms, and Device j at 7.64 ms. This distribution reflects the complexities of the protocol, which entails varying levels of computational load. The observed decrease in costs from the Control Server to Device j suggests that the protocol may efficiently offload specific computational tasks to the devices, with Device j showcasing the most excellent efficiency. This cost variation highlights the potential trade-offs between centralization and decentralization in the protocol design, with centralization leading to higher costs but potentially better control, and decentralization reducing costs but potentially increasing complexity.

B. STORAGE COST ANALYSIS

The credentials stored in the memory of the various participating entities contribute to the overall storage cost [36]. In this context, the control server (CS) $a_1, a_2, P, PK, h, D_2 =$

TABLE 5. Computation cost of the proposed protocol.

Peer	Total No. of Cryptographic Operations	Values	Cost in ms
Control Server	Hash Function = $4T_H$	$7T_H + 4T_X + 3T_{RE} + 2T_S + 3T_{XOR}$ $= 7(0.189) + 4(0.567) + 2(2.024) + 0$ $= 1.323 + 2.268 + 4.048$ $= 7.639$	7.64
	Multiplication = $4T_X$		
	Random number extraction = $3T_{RM}$		
	Scalar Multiplication = $2T_S$		
	XOR Operation = $3T_{XOR}$		
Device i	Hash Function = $4T_H$	$4T_H + 2T_X + 2T_{RE} + 2T_S + 3T_{XOR}$ $= 4(0.774) + 2(0.954) + 2(2.581) + 0$ $= 3.096 + 1.908 + 5.162$ $= 10.166$	10.17
	Multiplication = $2T_X$		
	Random number extraction = $2T_{RM}$		
	Scalar Multiplication = $2T_S$		
	XOR Operation = $3T_{XOR}$		
Device j	Hash Function = $3T_H$	$3T_H + 2T_X + 2T_{RE} + 2T_S + 3T_{XOR}$ $= 3(0.981) + 2(1.051) + 2(2.987) + 0$ $= 2.943 + 2.102 + 5.974$ $= 11.019$	11.02
	Multiplication = $2T_X$		
	Random number extraction = $2T_{RM}$		
	Scalar Multiplication = $2T_S$		
	XOR Operation = $3T_{XOR}$		
Total Computation Cost in Milliseconds (ms)		$14T_H + 8T_X + 7T_{RE} + 6T_S + 9T_{XOR}$	28.83 ms

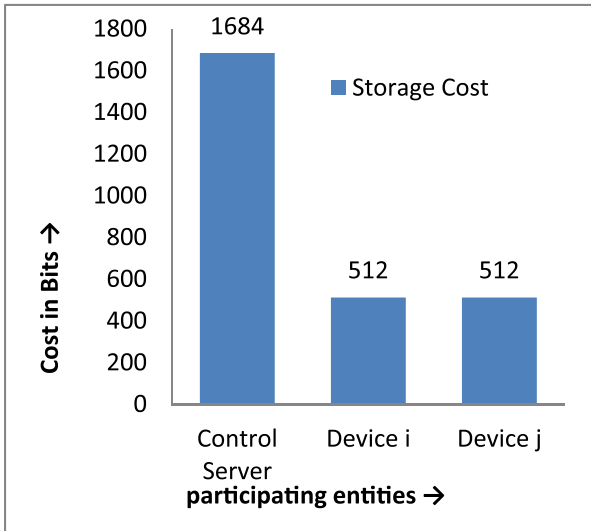


FIGURE 6. Storage costs analysis.

$PK_{N1} \oplus D_1 \oplus k$, and $D_3 = PK_{N2} \oplus h(D_1 || k)$ of cost $60 + 60 + 60 + 160 + 256 + 544 + 544 = 1684$ bits; device i stores PK_{N1} , PK_{N2} , ID_{Di} , and point P, resulting in a cost of 512 bits, and device j, which also stores PK_{N1} , PK_{N2} , ID_{Dj} , and point P, incurs the exact storage cost of 512 bits. When combining the costs of these three participating entities, a total storage cost of 2708 bits is measured which is shown in Table 6, as plotted in Figure 6.

C. COMMUNICATION COST ANALYSIS

The communication cost of the scheme is carefully balanced, determined by the bandwidth utilized during the authentication phase. Specifically, the messages exchanged between Device i and Device j. According to [35] and [36], the total space occupied by each parameter in a publicly transmitted message in the authentication phase of the protocol is as

TABLE 6. Storage cost analysis of the proposed protocol.

Entity	Parameters	Values	Cost in bits
Control Server (CS)	$\{a_1, a_2, P, PK, h(\cdot)\}$ and $\{D_2, D_3\}$	$60 + 60 + 60 + 160 + 256 + 544 + 544$	1684
Device i	$\{PK_{N1}, PK_{N2}, ID_{Di}, \text{and point } P\}$	$160 + 160 + 64 + 128$	512
Device j	$\{PK_{N1}, PK_{N2}, ID_{Dj}, \text{and point } P\}$	$160 + 160 + 64 + 128$	512
Total Storage Costs in Bits			2708

TABLE 7. Communication costs of the proposed protocol.

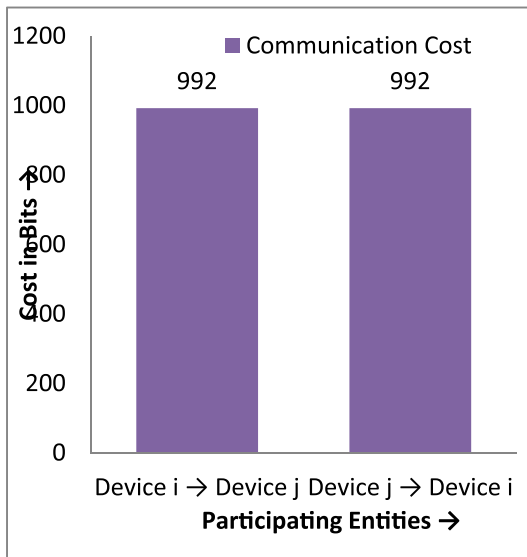
Participant	Message	Cost
Device i $\rightarrow$ Device j	$\{D_4, PK_{D2}, PK_{Di}, PK_{N1}, T\}$	992
Device j $\rightarrow$ Device i	$\{D_4^*, PK_{D1}, PK_{Dj}, PK_{N2}, T\}$	992
Communication Costs in Bits		1984

follows: The first message from Device i to Device j consists of $\{D_4, PK_{D2}, PK_{Di}, PK_{N1}, T\}$, with a total cost of $480 + 160 + 160 + 160 + 32 = 992$ bits. Conversely, the message from Device J to Device i includes $\{D_4^*, PK_{D1}, PK_{Dj}, PK_{N2}, T\}$, which also totals $480 + 160 + 160 + 160 + 31 = 992$ bits. Therefore, the combined bandwidth utilization is 960 bits from Device i to Device J and 960 bits in the reverse direction, resulting in a cumulative communication cost of 1920 bits. This cost is summarized in Table 7 and illustrated diagrammatically in Figure 7.

The figure illustrates the communication costs of the proposed authentication protocol, expressed in bits, between Device i and Device j. Both communication directions—Device i to Device j and Device j to Device i—incur an identical cost of 992 bits, highlighting the same bandwidth data exchange. This same bandwidth of data exchanged suggests that the proposed protocol involves mutual authentication and bidirectional message exchanges, ensuring an equal computational or messaging burden for both devices. The exchange of 992 data bits to and from these devices

TABLE 8. Comparative analysis regarding performance metrics.

Performance Metrics → Schemes↓	Communication cost (bits)	Computation Cost (ms)	Energy Consumption (J)
Zargar et al. [7]	2080	261.85	2.94
Algamadi et al. [22]	2144	31.46	0.5
Singh et al. [23]	3088	39.09	0.6
Son et al. [24]	3456	41.46	0.7
Sahoo et al. [25]	2192	178.1	1.9
Proposed	1984	28.83	0.4

**FIGURE 7.** Communication costs in bits.

reflects a careful balance between security and efficiency in the protocol design.

D. ENERGY CONSUMPTION

Upon executing the proposed protocol, a considerable amount of energy is utilized, as represented by the equation $E = E_1 \times E_2$. In this context, E_1 denotes the computation cost of the proposed protocol, precisely measured at 28.83 ms, while E_2 indicates the energy consumption associated with wireless data communication [37], [38], which is held constant at 10.88 Watt. By substituting these values into the formula, we calculate $E = 28.83 \times 10.88 = 313.68$ mJ, or 0.4 Joules. Consequently, the total energy consumed during the execution of the proposed protocol is 0.4 Joules.

E. COMPARATIVE ANALYSIS (PERFORMANCE METRICS)

When comparing the proposed protocol with state-of-the-art schemes like [7], [22], [23], [24], and [25] in terms of communication, computation costs, and energy consumption, the result demonstrated that the proposed protocol is better in all three metrics than all its competitors, as shown in Table 8 and plotted diagrammatically in Figure 8.

It is demonstrated that the communication cost of Zargar et al. [7] is 2080 bits, the computation cost is 261.85 ms, and the energy consumption is 2.94 joule. The proposed protocol is 4.61 % better in communication cost, 88.98% in computation cost, and 86.39% in energy consumption. The scheme presented by Algamadi et al. [22] has a communication cost of 2144 bits, a computation cost of 31.46 ms, and an energy consumption of 0.5 joules. The proposed protocol is 7.46% better in communication cost, 8.36% in computation cost, and 20% in energy consumption. The mechanism presented by Singh et al. [23] has a communication cost of 3088 bits, a computation cost of 39.09 ms, and an energy consumption of 0.6 j. The proposed protocol is 35.75% better in communication cost, 26.24%, and 33.33% in energy consumption. Similarly, the protocol presented by Son et al. [24] has a communication cost of 3456 bits, a computation cost of 41.46 ms, and an energy consumption of 0.7 j. The proposed protocol is 42.59% better in communication cost, 30.46% in computation cost, and 42.85% in energy consumption. Finally, the framework presented by Sahoo et al. [25] has a communication cost of 2192 bits, a computation cost of 178.1%, and an energy consumption of 1.9 j. The proposed protocol is 9.48% better in communication, 83.81% in computation cost, and 78.94% in energy consumption. Overall, the proposed protocol is an efficient and feasible solution.

F. COMPARATIVE ANALYSIS (SECURITY FUNCTIONALITIES)

Now, the proposed protocol can be checked for different attacks, including session key disclosure, replay, MITM, identity guessing, hash collision, forgery, ESL, DoS, and side-channel attacks, and security features, including untraceability, anonymity, forward secrecy, and key secrecy, as shown in Table 9. Whereas ✓ means the mentioned attack is not valid for the mentioned scheme, and the mentioned security feature existed in the mentioned scheme, while × means the mentioned feature does not exist and the attack mentioned attack is valid for the mentioned scheme.

The analysis in Table 8 means that [7], [23], and [25] are traceable and not anonymous, while [22], [24], and the proposed protocol offer untraceability and anonymity security features. The session key disclosure attack is only possible for [22] and [24] while all the other, including the proposed, are revisiting the said attack. Replay and DoS attacks are

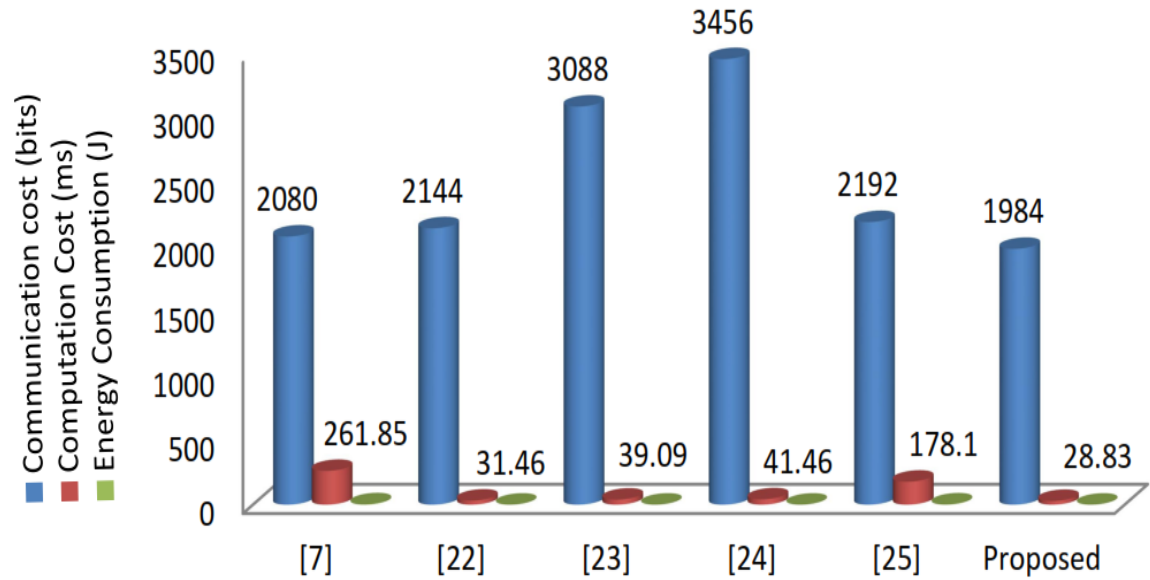


FIGURE 8. Communication cost comparison.

TABLE 9. Comparative analysis regarding security functionalities.

	Protocol →					
Security Functionalities↓	[7]	[22]	[23]	[24]	[25]	Proposed
Untraceability & Anonymity	×	✓	×	✓	×	✓
Session Key Disclosure Attack	✓	×	✓	×	✓	✓
Replay Attacks	×	✓	✓	✓	×	✓
Man-in-the-Middle Attack	×	×	✓	✓	✓	✓
Offline ID guessing Attack	✓	✓	✓	×	×	✓
Hash Collision Attack	✓	✓	×	✓	✓	✓
Forgery Attack	×	✓	×	✓	×	✓
Ephemeral Secret Leakage (ESL)	✓	×	✓	×	✓	✓
DoS Attack	×	✓	✓	✓	×	✓
Perfect Forward & Backward Secrecy	×	×	×	✓	✓	✓
Side Channel Attack	✓	✓	×	✓	×	✓
Key Secrecy	×	×	×	✓	×	✓

possible on [7] and [25], and the remaining all is withstanding these attacks. MITM attack applies only to [7] and [22], invalid for all the remaining. The identity utilized by [24] and [25] can easily be guessed, while in the remaining schemes, the attacker couldn't guess it. The scheme presented by Sing et al. [23] is based on SHA-1, which is vulnerable to hash collision attacks; the session secret keys from [7], [23], and [25] are forgeable, while the reaming schemes are resisting forgery attacks. The ephemeral secret is leaked from [22] and [24], the side channel attack is valid for [23] and [25], and the remaining all are safe from these attacks. The perfect forward/backward secrecy and confidentiality of [7], [22], and [23] are not availing, while the remaining all are offering these features. Overall, the proposed protocol is superior to that of its competitors.

VII. CONCLUSION

This article has proposed a verifiably secure and lightweight Device-to-Device (D2D) authentication protocol tailored for IoT networks with limited resources. The proposed protocol uses strong mutual authentication and lightweight cryptographic approaches to handle security, scalability, and efficiency issues in the IoT environment. A comprehensive security analysis has shown that the protocol resists common attacks like impersonation, DoS, replay, and man-in-the-middle attacks. Notably, the protocol's accuracy and compliance with security standards have been formally verified using the RoR model and ProVerif simulation, reassuring its reliability and trustworthiness. Performance evaluations show considerable gains in decreased computation, communication, storage cost, lower energy consumption, and

minimal bandwidth utilization compared to current systems, making the protocol ideal for implementation in IoT networks having a resource-constrained nature. Future development will concentrate on integrating the protocol with new IoT standards and expanding it to accommodate dynamic network topologies.

REFERENCES

- [1] A. Shahidinejad and A. Jemal, "Decentralized lattice-based device-to-device authentication for the edge-enabled IoT," *IEEE Syst. J.*, vol. 17, no. 4, pp. 6623–6633, Apr. 2023.
- [2] Z. Shang, M. Ma, and X. Li, "A secure group-oriented device-to-device authentication protocol for 5G wireless networks," *IEEE Trans. Wireless Commun.*, vol. 19, no. 11, pp. 7021–7032, Nov. 2020.
- [3] S. W. Shah, N. F. Syed, A. Shaghaghi, A. Anwar, Z. Baig, and R. Doss, "LCDA: Lightweight continuous device-to-device authentication for a zero trust architecture (ZTA)," *Comput. Secur.*, vol. 108, Sep. 2021, Art. no. 102351.
- [4] D. Schürmann, A. Brüsch, S. Sigg, and L. Wolf, "BANDANA—Body area network device-to-device authentication using natural gait," in *Proc. IEEE Int. Conf. Pervasive Comput. Commun. (PerCom)*, Mar. 2017, pp. 190–196.
- [5] H. Kwon, C. Hahn, D. Kim, K. Kang, and J. Hur, "Secure device-to-device authentication in mobile multi-hop networks," in *Proc. 9th Int. Conf. Wireless Algorithms, Syst., Appl.*, Harbin, China. Cham, Switzerland: Springer, 2014, pp. 267–278.
- [6] T. Nandy, M. Y. I. Idris, R. M. Noor, A. W. A. Wahab, S. Bhattacharyya, R. Kolandaisamy, and M. Yahuza, "A secure, privacy-preserving, and lightweight authentication scheme for VANETs," *IEEE Sensors J.*, vol. 21, no. 18, pp. 20998–21011, Sep. 2021.
- [7] G. R. Zargar, H. Barati, and A. Barati, "An authentication mechanism based on blockchain for IoT environment," *Cluster Comput.*, vol. 27, no. 9, pp. 13239–13255, Dec. 2024.
- [8] P. Sarkar and A. Nag, "Lattice-based device-to-device authentication and key exchange protocol for IoT system," *Int. J. Inf. Technol.*, vol. 16, no. 7, pp. 4167–4179, Oct. 2024.
- [9] J. Lee, J. Oh, D. Kwon, M. Kim, S. Yu, N.-S. Jho, and Y. Park, "PUFTAP-IoT: PUF-based three-factor authentication protocol in IoT environment focused on sensing devices," *Sensors*, vol. 22, no. 18, p. 7075, Sep. 2022.
- [10] R. Hajian, S. H. Erfani, and S. Kumari, "A lightweight authentication and key agreement protocol for heterogeneous IoT with special attention to sensing devices and gateway," *J. Supercomput.*, vol. 78, no. 15, pp. 16678–16720, Oct. 2022.
- [11] C. Sharma, M. Aljaidi, Saurabh, M. Alshammari, and A. Alanazi, "Security enhancement for IoT using mutual authentication based lightweight algorithm," *Adv. Nonlinear Variational Inequalities*, vol. 28, no. 1, pp. 479–505, Nov. 2024.
- [12] H. S. Sengar, "An ECC based secure authentication protocol for M2M communication in industrial IoT edge device," *Int. J. Res. Appl. Sci. Eng. Technol.*, vol. 12, no. 6, pp. 30–40, Jun. 2024.
- [13] D. Liu and T. Ji, "Security analysis and provision of authentication protocol, based on peer-to-peer structure in IoT platform," *Sci. Rep.*, vol. 14, no. 1, pp. 1–16, Oct. 2024.
- [14] Z. Cui, J. Ling, and X. Zhang, "Design of efficient device communication authentication protocol in large-scale Internet of Things scenarios," in *Proc. Int. Conf. Artif. Intell., Syst. Netw. Secur.*, Dec. 2023, pp. 246–251.
- [15] F. Li, H. Xu, Q. Song, L. Zhang, X. Du, N. Tong, and D. Wang, "BLMA: Editable blockchain-based lightweight massive IIoT device authentication protocol," *IEEE Internet Things J.*, vol. 10, no. 24, pp. 21633–21646, Dec. 2023.
- [16] A. A. Alzahrani, "VSKAP-IoD: A verifiably secure key agreement protocol for securing IoD environment," *IEEE Access*, vol. 12, pp. 58039–58056, 2024.
- [17] A. Alzahrani, "RLKS-TMS: A robust and lightweight key agreement scheme for telemedicine system," *IEEE Access*, vol. 12, pp. 108233–108247, 2024.
- [18] A. Alzahrani, "Developing a provable secure and cloud-centric authentication protocol for the e-Healthcare system," *IEEE Access*, vol. 12, pp. 183665–183687, 2024.
- [19] I. Keshta, "A CRC-based authentication model and ECC-based authentication protocol for resource-constrained IoT applications," *IEEE Access*, vol. 12, pp. 156765–156784, 2024.
- [20] F. Algarni, "A lightweight and secure authentication protocol for visually impaired and handicapped people in the telehealth system," *Alexandria Eng. J.*, vol. 106, pp. 793–808, Nov. 2024.
- [21] A. Alzahrani and H. A. Alzahrani, "A privacy-preserving and energy efficient authentication protocol for the cloud-based e-healthcare system," *Alexandria Eng. J.*, vol. 118, pp. 59–90, Apr. 2025.
- [22] A. M. Alghamdi, "Design and analysis of lightweight and robust authentication protocol for securing the resource constrained IIoT environment," *PLoS ONE*, vol. 20, no. 2, Feb. 2025, Art. no. e0318064.
- [23] J. Singh, A. Gimekar, and S. Venkatesan, "An efficient lightweight authentication scheme for human-centered industrial Internet of Things," *Int. J. Commun. Syst.*, vol. 36, no. 12, p. 4189, Nov. 2019.
- [24] S. Son, J. Lee, M. Kim, S. Yu, A. K. Das, and Y. Park, "Design of secure authentication protocol for cloud-assisted telecare medical information system using blockchain," *IEEE Access*, vol. 8, pp. 192177–192191, 2020.
- [25] S. S. Sahoo, S. Mohanty, and B. Majhi, "A secure three factor based authentication scheme for health care systems using IoT enabled devices," *J. Ambient Intell. Humanized Comput.*, vol. 12, no. 1, pp. 1419–1434, Jan. 2021.
- [26] R. Mayrhofer and S. Sigg, "Adversary models for mobile device authentication," *ACM Comput. Surveys*, vol. 54, no. 9, pp. 1–35, Dec. 2022.
- [27] C. Wang, Y. Wang, Y. Chen, H. Liu, and J. Liu, "User authentication on mobile devices: Approaches, threats and trends," *Comput. Netw.*, vol. 170, Apr. 2020, Art. no. 107118.
- [28] D. Rachmawati, J. T. Tarigan, and A. B. C. Ginting, "A comparative study of message digest 5(MD5) and SHA256 algorithm," *J. Phys., Conf. Ser.*, vol. 978, Mar. 2018, Art. no. 012116.
- [29] B. Blanchet, B. Smyth, V. Cheval, and M. Sylvestre, "ProVerif 2.00: Automatic cryptographic protocol verifier, user manual and tutorial," *Version*, vol. 16, pp. 5–16, May 2018.
- [30] I. Cervesato, "The Dolev–Yao intruder is the most powerful attacker," in *Proc. 16th Annu. Symp. Log. Comput. Sci.*, vol. 1, 2001, pp. 1–2.
- [31] R. Canetti and H. Krawczyk, "Universally composable notions of key exchange and secure channels," in *Advances in Cryptology*. Berlin, Germany: Springer, 2002, pp. 337–351.
- [32] M. Haus, M. Waqas, A. Y. Ding, Y. Li, S. Tarkoma, and J. Ott, "Security and privacy in device-to-device (D2D) communication: A review," *IEEE Commun. Surveys Tuts.*, vol. 19, no. 2, pp. 1054–1079, 2nd Quart., 2017.
- [33] S. U. Jan, A. Ghani, A. Alzahrani, M. U. Tariq, F. Algarni, and H. A. Naqvi, "SKALP: Secure key agreement and lightweight protocol for dew-assisted IoT enabled edge computing," *Trans. Emerg. Telecommun. Technol.*, vol. 35, no. 9, p. 5035, Sep. 2024.
- [34] X. Zhou and X. Tang, "Research and implementation of RSA algorithm for encryption and decryption," in *Proc. 6th Int. Forum Strategic Technol.*, vol. 2, Aug. 2011, pp. 1118–1121.
- [35] M. Egele, D. Brumley, Y. Fratantonio, and C. Kruegel, "An empirical study of cryptographic misuse in Android applications," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, 2013, pp. 73–84.
- [36] H. H. Kilinc and T. Yanik, "A survey of SIP authentication and key agreement schemes," *IEEE Commun. Surveys Tuts.*, vol. 16, no. 2, pp. 1005–1023, 2nd Quart., 2014.
- [37] P. Patil, P. Narayankar, D. G. Narayan, and S. M. Meena, "A comprehensive evaluation of cryptographic algorithms: DES, 3DES, AES, RSA and blowfish," *Proc. Comput. Sci.*, vol. 78, pp. 617–624, Jan. 2016.
- [38] Z. U. I. Adil, M. Iqbal Khan, K. Sanam, S. U. R. Malik, S. A. Moqurrah, and G. Srivastava, "LightAuth: A lightweight sensor nodes authentication framework for smart health system," *Expert Syst.*, vol. 42, no. 2, p. 13756, Feb. 2025.



NAIF ALZHRANI received the master's degree in security and computing from RMIT University and the Ph.D. degree in cybersecurity from Portland State University. He is currently an Assistant Professor with the Cybersecurity Department, University of Jeddah. His research interests include recent trends in security, cryptography, the IoT security, and game theory application-based security.

...